



Vulnerability Assessment & Penetration Testing

Introduction

This practical focuses on learning how to identify and analyze security vulnerabilities using a safe virtual lab environment. A Kali Linux machine is used as the attacker system, and Metasploitable 3 is set up as the vulnerable target. Tools like OpenVAS and Nikto are used to scan the system, find weaknesses, and understand their severity. All results are documented with screenshots, CVSS scores, and a basic risk assessment. The goal is to practice real-world cybersecurity skills and create a clear, professional report based on the findings.

1. Theoretical Knowledge

1. Understanding Security Assessment

Objective:

To learn how to evaluate systems using open-source tools and frameworks without relying on paid solutions.

Explanation:

A Security Assessment is a structured process of identifying weaknesses in systems, networks, and applications. The goal is not to hack or damage systems, but to highlight risks and recommend security improvements.

Key Types of Security Testing:

1. Vulnerability Assessment (VA)

- **Focus:** Find weaknesses.
- **Tools:**
 - OpenVAS/GVM (free vulnerability scanner)
 - Nmap (port scanning)
- **Output:** List of vulnerabilities, CVSS scores, and remediation suggestions.

2. Penetration Testing (PT)

- **Focus:** Simulate real attacks.
- **Tools:**
 - Kali Linux tools
 - Metasploit Framework
 - OWASP ZAP
- **Output:** Successful exploits, proof-of-concept.

3. Compliance Testing

- **Focus:** Verify compliance with security standards.
- **Standards/Frameworks:**
 - NIST guidelines



- CIS Benchmarks
- ISO 27001 Controls
- **Output:** Checklist-based compliance status.

2. VAPT Methodology

Objective:

To follow a structured, industry-standard approach for conducting security assessments.

Phases of VAPT:

1. Planning

- Define scope, rules, and limitations.
- **Tools:** Dradis CE for planning and documentation.

2. Discovery / Scanning

- **Network scanning:** Nmap
- **Web scanning:** OWASP ZAP, Nikto

3. Attack / Exploitation

- **Validate vulnerabilities using:**
 - Metasploit Framework
 - Manual exploitation techniques
- **Purpose:** Confirm real-world risk.

4. Reporting

- **Document findings with:**
 - Screenshots
 - CVSS scores
 - Impact & risk level
- **Templates available at:** Pentest-Tools / GitHub

How to Learn:

- Study OWASP Web Security Testing Guide (WSTG)
- Practice labs like Juice Shop, Metasploitable, VulnHub

3. Security Standards & Compliance

Objective:

To understand the importance of regulations and compliance in security testing.

Key Standards:

- ISO 27001 – Information Security Management
- GDPR – Data protection (EU)
- HIPAA – Healthcare data privacy
- NIST SP 800-53 – Security controls
- CIS Benchmarks – System hardening guidelines

How to Learn:



- Start with OWASP Top 10, which highlights the most common and critical vulnerabilities in web applications.

4. Risk Assessment Basics

Objective:

To measure and prioritize vulnerabilities based on impact.

Components:

1. CVSS (Common Vulnerability Scoring System)

- Evaluates severity on a scale of 0.0 to 10.0
- Use the official calculator: NVD CVSS Calculator
- **Input details such as:**
 - Attack Vector
 - Attack Complexity
 - Privileges Required
 - User Interaction
 - Confidentiality/Integrity/Availability impact

2. Risk Matrix (3×3 Grid)

- Likelihood (Low/Medium/High)
- Impact (Low/Medium/High)
- Helps prioritize focus areas quickly.

5. Common Vulnerabilities

Objective:

To identify common security weaknesses during assessments.

Network Vulnerabilities:

- Misconfigurations
- Open ports
- Outdated services
- Weak SSH/Telnet credentials
- Incorrect firewall rules
- **Tools:** Nmap, OpenVAS

Web Vulnerabilities:

- **SQL Injection**
- XSS
- CSRF
- Directory Traversal
- Misconfigured headers
- **Tools:** ZAP, Burp Suite, Nikto

How to Learn:

Practice using:

- Metasploitable 2/3



- VulnHub VMs
- OWASP Juice Shop

6. Documentation Fundamentals

Objective:

To create professional reports and maintain structured notes.

Tools Used:

- Dradis CE – Report collaboration
- CherryTree – Technical notes
- Google Sheets/Excel – Vulnerability tracking
- Markdown / GitHub templates – Clean reporting format

How to Learn:

Use free pentesting templates available on GitHub.

2. Practical Application

1. Setting Up the Testing Environment

1.1 Install Kali Linux

Kali Linux is a penetration-testing operating system used for vulnerability assessment and ethical hacking.

Steps:

1. Download Kali Linux ISO from the official website.
2. Install it on VirtualBox/VMware.
3. Allocate:
 - 2–4 GB RAM
 - 2 CPU cores
 - 25+ GB storage

1.2 Install Metasploitable 3 (Target Machine)

Metasploitable 3 is an intentionally vulnerable VM for hands-on security testing.

Steps:

1. Download Metasploitable 3 from GitHub (pre-built VM or build manually).
2. Import into VirtualBox:
 - Machine → Add → Select .vbox file
3. Start the VM.

1.3 Configure Network

To allow Kali to test Metasploitable:

- Go to Network Settings
- Select: NAT Network or Host-Only Adapter
- Ensure both VMs show IPs with:

ifconfig (Linux)



ipconfig (Windows)

Example:

- Kali: 192.168.1.116

```
(kali@kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.1.116 netmask 255.255.255.0 broadcast 192.168.1.255
    inet6 fe80::911e:9a87:5281:86f8 prefixlen 64 scopeid 0<link>
    ether 08:00:27:1f:b7:23 txqueuelen 1000 (Ethernet)
    RX packets 84 bytes 15518 (15.1 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 85 bytes 11626 (11.3 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 3178 bytes 617446 (602.9 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 3178 bytes 617446 (602.9 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

- Metasploitable: 192.168.1.117

```
C:\Users\Pooja>ipconfig

Windows IP Configuration

Ethernet adapter Local Area Connection:

    Connection-specific DNS Suffix . : 
    Link-local IPv6 Address . . . . . : fe80::fc8f:4aca:854e:408a%11
    IPv4 Address. . . . . : 192.168.1.117
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.1.1

Tunnel adapter isatap.{7B43CCEB-D112-4606-86C1-BEDEAA8705CB}:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix . :
```

2. Vulnerability Scanning

In this section, two industry-standard tools—OpenVAS/GVM and Nikto—were used to perform comprehensive vulnerability scanning on the Metasploitable 2 machine. These tools help identify system-level and web-level security weaknesses that attackers can exploit.

2.1 OpenVAS (GVM) Vulnerability Scan

Step 1: OpenVAS Setup and Initialization

OpenVAS was installed and configured in Kali Linux. The initial setup ensures all required components such as PostgreSQL, Greenbone Vulnerability Manager (GVM), Greenbone Security Assistant (GSA), and the NVT (Network Vulnerability Tests) feed are correctly initialized.

Commands used:



sudo gvm-setup

```

(kali@kali) ~$ sudo gvm-setup
[sudo] password for kali:
This script is provided and maintained by Debian and Kali.
If you find any issue in this script, please report it directly to Debian or Kali

[>] Starting PostgreSQL service

[>] Creating GVM's certificate files

[>] Creating PostgreSQL database
[i] User _gvm already exists in PostgreSQL
[i] Database gvmdb already exists in PostgreSQL
[i] Role DBA already exists in PostgreSQL

[*] Applying permissions
NOTICE: role "_gvm" has already been granted membership in role "dba" by role "postgres"
GRANT ROLE
[i] Extension uuid-ossp already exists for gvmdb database
[i] Extension pgcrypto already exists for gvmdb database
[i] Extension pg-gvm already exists for gvmdb database
[>] Migrating database
[>] Checking for GVM admin user
[*] Configure Feed Import Owner
[*] Update GVM feeds
Running as root. Switching to user '_gvm' and group '_gvm'.
Trying to acquire lock on /var/lib/openvas/feed-update.lock
Acquired lock on /var/lib/openvas/feed-update.lock
  Downloading Notus files from rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/vt-data/notus/ to /var/lib/notus
  Downloading NASL files from rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/vt-data/nasl/ to /var/lib/openvas/plugins
Releasing lock on /var/lib/openvas/feed-update.lock

Trying to acquire lock on /var/lib/gvm/feed-update.lock
Acquired lock on /var/lib/gvm/feed-update.lock
  Downloading SCAP data from rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/scap-data/ to /var/lib/gvm/scap-data
  Downloading CERT-Bund data from rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/cert-data/ to /var/lib/gvm/cert-data
  Downloading gvmdb data from rsync://feed.community.greenbone.net/community/data-feed/24.10/ to /var/lib/gvm/data-objects/gvmdb
Releasing lock on /var/lib/gvm/feed-update.lock

[*] Checking Default scanner
08b69003-5fc2-4037-a479-93b440211c73 OpenVAS /run/ospd/ospd.sock 0 OpenVAS Default
[i] No need to alter default scanner

[*] Done
[i] Admin user already exists for GVM
[i] If you have forgotten it, you can change it. See gvmdb manpage for more information

[>] You can now run gvm-check-setup to make sure everything is correctly configured
```

sudo gvm-check-setup

```

(kali@kali) ~$ sudo gvm-check-setup
[sudo] password for kali:
gvm-check-setup 25.04.0
Test completeness and readiness of GVM-25.04.0
Step 1: Checking OpenVAS (Scanner) ...
  OK: OpenVAS Scanner is present in version 23.23.1.
  OK: Notus Scanner is present in version 22.7.2.
  OK: Server CA Certificate is present as /var/lib/gvm/CA/servercert.pem.
Checking permissions of /var/lib/openvas/gnupg/*
  OK: _gvm owns all files in /var/lib/openvas/gnupg
  OK: redis-server is present.
  OK: scanner (db.address setting) is configured properly using the redis-server socket: /var/run/redis-openvas/redis-server.sock
  OK: the mqtt_server_url is defined in /etc/openvas/openvas.conf
  OK: _gvm owns all files in /var/lib/openvas/plugins
  OK: NVT collection in /var/lib/openvas/plugins contains 94933 NVTs.
  OK: The notus directory /var/lib/notus/products contains 510 NVTs.
Checking that the obsolete redis database has been removed
Could not connect to Redis at /var/run/redis-openvas/redis-server.sock: No such file or directory
  OK: No old Redis DB
Starting ospd-openvas service
Waiting for ospd-openvas service
  OK: ospd-openvas service is active.
  OK: ospd-OpenVAS is present in version 22.9.0.
Step 2: Checking GVM Manager ...
  OK: GVM Manager (gvmdb) is present in version 26.2.1.
Step 3: Checking Certificates ...
  OK: GVM client certificate is valid and present as /var/lib/gvm/CA/clientcert.pem.
  OK: Your GVM certificate infrastructure passed validation.
Step 4: Checking data ...
  OK: SCAP data found in /var/lib/gvm/scap-data.
  OK: CERT data found in /var/lib/gvm/cert-data.
Step 5: Checking PostgreSQL DB and user ...
  OK: PostgreSQL version and default port are OK.
  gvmdb | _gvm | UTF8 | libc | en_US.UTF-8 | en_US.UTF-8 | | |
16436|pg-gvm|10|2200|f|22.6|
  OK: At least one user exists.
Step 6: Checking Greenbone Security Assistant (GSA) ...
  OK: Greenbone Security Assistant is present in version 24.7.0-git.
Step 7: Checking if GVM services are up and running ...
Starting gvmdb service
Waiting for gvmdb service
  OK: gvmdb service is active.
Starting gsad service
Waiting for gsad service
  OK: gsad service is active.
Step 8: Checking few other requirements ...
  OK: nmap is present.
  OK: ssh-keygen found, LSC credential generation for GNU/Linux targets is likely to work.
```



```
Checking permissions of /var/lib/openvas/gnupg/*
OK: _gvm owns all files in /var/lib/openvas/gnupg
OK: redis-server is present.
OK: scanner (db_address setting) is configured properly using the redis-server socket: /var/run/redis-openvas/redis-server.sock
OK: the mqtt_server_uri is defined in /etc/openvas/openvas.conf
OK: _gvm owns all files in /var/lib/openvas/plugins
OK: NVT collection in /var/lib/openvas/plugins contains 94933 NVTs.
OK: The notus directory /var/lib/notus/products contains 510 NVTs.
Checking that the obsolete redis database has been removed
Could not connect to Redis at /var/run/redis-openvas/redis-server.sock: No such file or directory
OK: No old Redis DB
Starting ospd-openvas service
Waiting for ospd-openvas service
OK: ospd-openvas service is active.
OK: ospd-OpenVAS is present in version 22.9.0.
Step 2: Checking GVM Manager ...
OK: GVM Manager (gvm) is present in version 26.2.1.
Step 3: Checking Certificates ...
OK: GVM client certificate is valid and present as /var/lib/gvm/CA/clientcert.pem.
OK: Your GVM certificate infrastructure passed validation.
Step 4: Checking data ...
OK: SCAP data found in /var/lib/gvm/scap-data.
OK: CERT data found in /var/lib/gvm/cert-data.
Step 5: Checking PostgreSQL DB and user ...
OK: PostgreSQL version and default port are OK.
gvm | _gvm | UTF8 | libc | en_US.UTF-8 | en_US.UTF-8 | | |
16436|pg-gvm|10|2200|f|22.6||
OK: At least one user exists.
Step 6: Checking Greenbone Security Assistant (GSA) ...
OK: Greenbone Security Assistant is present in version 24.7.0-git.
Step 7: Checking if GVM services are up and running ...
Starting gvm service
Waiting for gvm service
OK: gvm service is active.
Starting gsad service
Waiting for gsad service
OK: gsad service is active.
Step 8: Checking few other requirements...
OK: nmap is present.
OK: ssh-keygen found, LSC credential generation for GNU/Linux targets is likely to work.
OK: nsis found, LSC credential package generation for Microsoft Windows targets is likely to work.
OK: xsltproc found.
WARNING: Your password policy is empty.
SUGGEST: Edit the /etc/gvm/pwpolicy.conf file to set a password policy.
Step 9: Checking greenbone-security-assistant...
OK: greenbone-security-assistant is installed

It seems like your GVM-25.04.0 installation is OK.
```

sudo gvm-start

```
---(kali@kali):~$
$ sudo gvm-start
[sudo] password for kali:
[+] Please wait for the GVM services to start.
[+] You might need to refresh your browser once it opens.
[+] Web UI (Greenbone Security Assistant): https://127.0.0.1:9392

• gsad.service - Greenbone Security Assistant daemon (gsad)
  Loaded: loaded (/usr/lib/systemd/system/gsad.service; disabled; preset: disabled)
  Active: active (running) since Thu 2025-12-04 12:35:19 EST; 58ms ago
  Invocation: 81848f36b1914295a14bdacbf35fc919
  Docs: man:gsad(8)
        https://www.greenbone.net
  Main PID: 2723 (gsad)
  Tasks: 1 (limit: 4546)
  Memory: 224K (peak: 2M)
  CPU: 31ms
  CGroup: /system.slice/gsad.service
          └─723 /usr/sbin/gsad --foreground --listen 127.0.0.1 --port 9392

Dec 04 12:35:18 kali systemd[1]: Starting gsad.service - Greenbone Security Assistant daemon (gsad) ...
Dec 04 12:35:19 kali systemd[1]: Started gsad.service - Greenbone Security Assistant daemon (gsad).

• gvm.service - Greenbone Vulnerability Manager daemon (gvm)
  Loaded: loaded (/usr/lib/systemd/system/gvm.service; disabled; preset: disabled)
  Active: active (running) since Thu 2025-12-04 12:35:13 EST; 5s ago
  Invocation: ac49c3ba4b9447f88376d61f85eeaf
  Docs: man:gvm(8)
  Process: 2624 ExecStart=/usr/sbin/gvm --osp-vt-update=/run/ospd/ospd.sock --listen-group=gvm (code=exited, status=0/SUCCESS)
  Main PID: 2626 (gvm)
  Tasks: 2 (limit: 4546)
  Memory: 8.4M (peak: 9.7M)
  CPU: 240ms
  CGroup: /system.slice/gvm.service
          └─2626 "gvm: Manage p" --osp-vt-update=/run/ospd/ospd.sock --listen-group=gvm
          └─726 "gvm: Manage p" --osp-vt-update=/run/ospd/ospd.sock --listen-group=gvm

Dec 04 12:35:18 kali systemd[1]: Starting gvm.service - Greenbone Vulnerability Manager daemon (gvm) ...
Dec 04 12:35:19 kali systemd[1]: gvm.service: Can't open PID file /run/gvm/gvm.pid (yet?) after start: No such file or directory
Dec 04 12:35:13 kali systemd[1]: Started gvm.service - Greenbone Vulnerability Manager daemon (gvm).

• ospd-openvas.service - OSPd Wrapper for the OpenVAS Scanner (ospd-openvas)
  Loaded: loaded (/usr/lib/systemd/system/ospd-openvas.service; disabled; preset: disabled)
  Active: active (running) since Thu 2025-12-04 12:35:10 EST; 9s ago
  Invocation: 22d49fc2497b4c3dbf98acd3047445b5
  Docs: man:ospd-openvas(8)
        man:openvas(8)
  Process: 2469 ExecStart=/usr/bin/ospd-openvas --config /etc/gvm/ospd-openvas.conf --log-config /etc/gvm/ospd-logging.conf (code=exited, status=0/SUCCESS)
  Main PID: 2596 (ospd-openvas)
  Tasks: 5 (limit: 4546)
```




```
Docs: man:gsad(8)
https://www.greenbone.net
Main PID: 2723 (gsad)
Tasks: 1 (limit: 4546)
Memory: 224K (peak: 2M)
CPU: 31ms
CGroup: /system.slice/gsad.service
--2723 /usr/sbin/gsad --foreground --listen 127.0.0.1 --port 9392

Dec 04 12:35:18 kali systemd[1]: Starting gsad.service - Greenbone Security Assistant daemon (gsad) ...
Dec 04 12:35:19 kali systemd[1]: Started gsad.service - Greenbone Security Assistant daemon (gsad).

● gvm.service - Greenbone Vulnerability Manager daemon (gvm)
   Loaded: loaded (/usr/lib/systemd/system/gvm.service; disabled; preset: disabled)
   Active: active (running) since Thu 2025-12-04 12:35:13 EST; 5s ago
   Invocation: aca9c3ba40a9447f88376861f85eefa0
   Docs: man:gvm(8)
   Process: 2624 ExecStart=/usr/sbin/gvmd --osp-vt-update=/run/ospd/ospd.sock --listen-group=gvm (code=exited, status=0/SUCCESS)
   Main PID: 2626 (gvmd)
   Tasks: 2 (limit: 4546)
   Memory: 8.4M (peak: 9.7M)
   CPU: 240ms
   CGroup: /system.slice/gvmd.service
           └─626 "gvmd: Manage p" --osp-vt-update=/run/ospd/ospd.sock --listen-group=gvm
             └─726 "gvmd: Manage p" --osp-vt-update=/run/ospd/ospd.sock --listen-group=gvm

Dec 04 12:35:10 kali systemd[1]: Starting gvm.service - Greenbone Vulnerability Manager daemon (gvm) ...
Dec 04 12:35:10 kali systemd[1]: gvm.service: Can't open PID file '/run/gvmd/gvmd.pid' (yet?) after start: No such file or directory
Dec 04 12:35:13 kali systemd[1]: Started gvm.service - Greenbone Vulnerability Manager daemon (gvm).

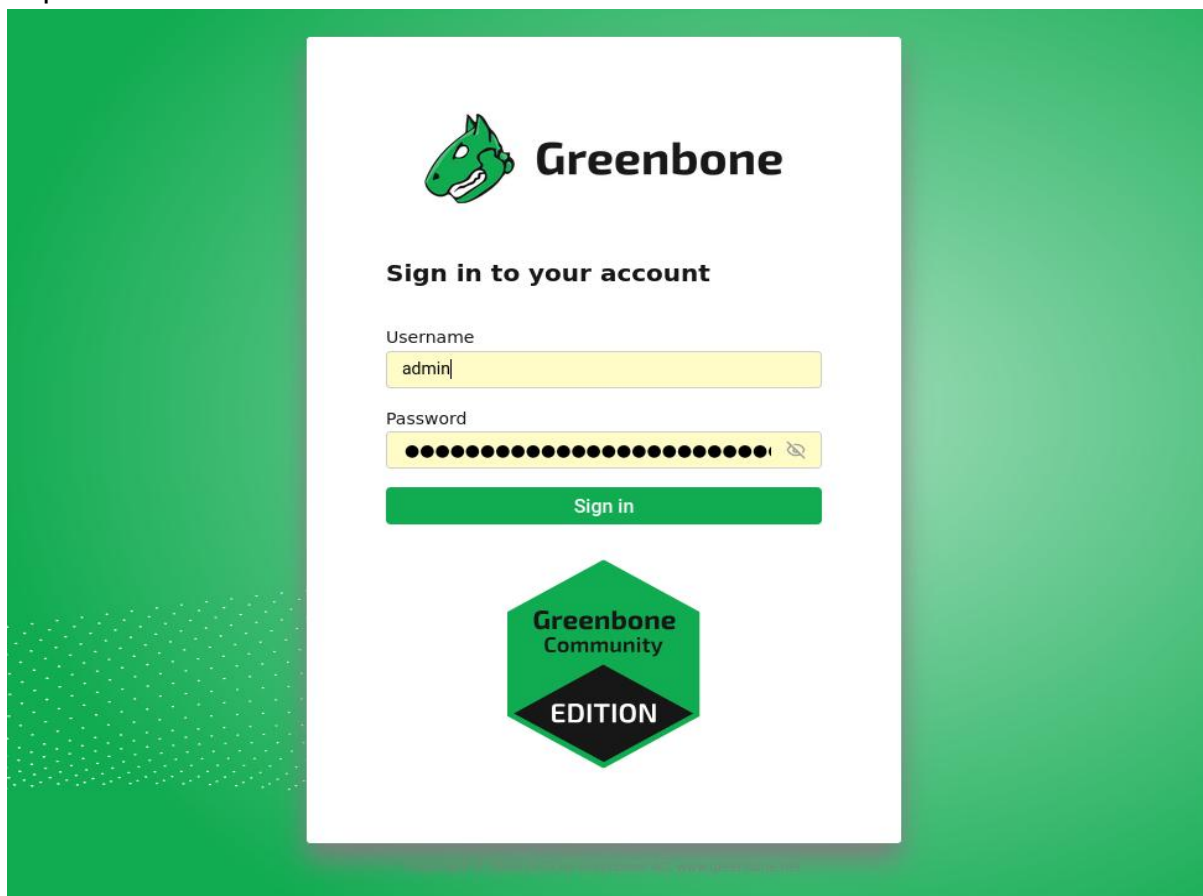
● ospd-openvas.service - OSPd Wrapper for the OpenVAS Scanner (ospd-openvas)
   Loaded: loaded (/usr/lib/systemd/system/ospd-openvas.service; disabled; preset: disabled)
   Active: active (running) since Thu 2025-12-04 12:35:10 EST; 9s ago
   Invocation: 22d49fcd497bdc3dbf90acd304744505
   Docs: man:ospd-openvas(8)
   Process: 2469 ExecStart=/usr/bin/ospd-openvas --config /etc/gvm/ospd-openvas.conf --log-config /etc/gvm/ospd-logging.conf (code=exited, status=0/SUCCESS)
   Main PID: 2596 (ospd-openvas)
   Tasks: 5 (limit: 4546)
   Memory: 86M (peak: 106.3M)
   CPU: 3.596s
   CGroup: /system.slice/ospd-openvas.service
           └─2596 /usr/bin/python3 /usr/bin/ospd-openvas --config /etc/gvm/ospd-openvas.conf --log-config /etc/gvm/ospd-logging.conf
             └─2686 /usr/bin/python3 /usr/bin/ospd-openvas --config /etc/gvm/ospd-openvas.conf --log-config /etc/gvm/ospd-logging.conf

Dec 04 12:34:57 kali systemd[1]: Starting ospd-openvas.service - OSPd Wrapper for the OpenVAS Scanner (ospd-openvas) ...
Dec 04 12:35:10 kali systemd[1]: Started ospd-openvas.service - OSPd Wrapper for the OpenVAS Scanner (ospd-openvas).

[>] Opening Web UI (https://127.0.0.1:9392) in: 5... 4... 3... 2... 1...
```

Once all services were running, the Greenbone Security Assistant (GSA) web UI was accessible at:

<https://127.0.0.1:9392>





The login credentials were obtained during the setup process.

Step 2: Creating a Scan Target

Inside the GVM dashboard:

- **Navigate to Configuration → Targets → New Target**
- **Target Name:** Metasploitable2
- **Host/IP:** 192.168.1.114
- **Port List:** All TCP

This target configuration allows OpenVAS to analyze all open services on the machine.

 Targets 1 of 1

Name ↑	Hosts ↑↓	IPs ↑↓	Port List ↑↓	Credentials	Actions
Metasploitable2	192.168.1.114	1	All IANA assigned TCP		  

Apply to page contents   

(Applied filter: sort=name first=1 rows=10)

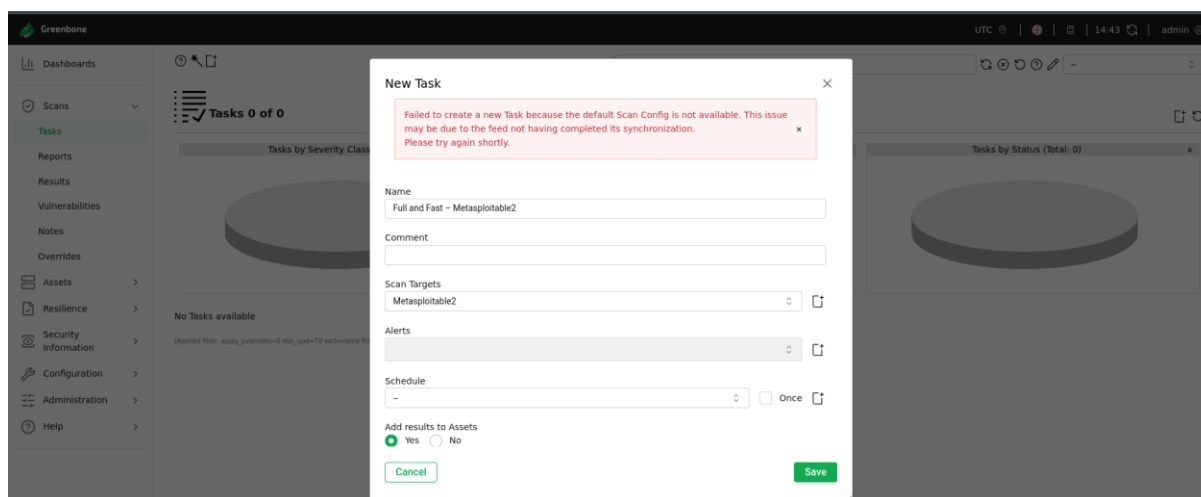
Copyright © 2009-2025 by Greenbone AG, www.greenbone.net

Step 3: Creating the Vulnerability Scan Task

Next, a scan task was created:

- **Go to Scans → Tasks → New Task**
- **Task Name:** Full and Fast – Metasploitable2
- **Target:** Metasploitable2 (192.168.1.114)
- **Scan Config:** Full and Fast

The “Full and Fast” profile performs a wide vulnerability test while optimizing scan performance.



Step 4: Running the Scan

Once the task was created, the scan was executed by clicking Start. OpenVAS began analyzing services such as SSH, FTP, Telnet, SMB, Apache, MySQL, PostgreSQL, and others running on Metasploitable.

OpenVAS performs:

- Banner grabbing
- Service fingerprinting
- CVE-based checks
- Misconfiguration identification
- Weak authentication detection

Step 5: Analyzing Scan Results

After completion, the scan results were reviewed from the Reports section.

The report included:

- CVSS Scores (0–10)
- CVE Identifiers (e.g., CVE-2010-XXXX)
- Severity Levels: High, Medium, Low, Log
- Affected Service and Port
- Proof-of-concept details
- Recommended Remediation

Common high-severity issues on Metasploitable include:

- Outdated and vulnerable vsftpd server (backdoor vulnerability)
- Weak SSH configurations
- Anonymous FTP access
- Outdated Apache web server
- Open RPC services
- Misconfigured MySQL server

Exporting the report:

Reports → Select latest report → Export as PDF or CSV



These exported files were used for documentation and evidence.

2.2 Web Server Scanning with Nikto

Nikto is a specialized web vulnerability scanner. It performs checks for outdated software, misconfigurations, dangerous HTTP methods, and known vulnerabilities.

Command Used

nikto -h http://192.168.1.114

```
(kali@kali) ~
$ nikto -h http://192.168.1.114
- Nikto v2.5.0

+ Target IP: 192.168.1.114
+ Target Hostname: 192.168.1.114
+ Target Port: 80
+ Start Time: 2025-12-04 12:41:53 (GMT-5)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /%PHE8885F2A0-3C92-11d3-A349-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /%PHE95568F36-0428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /%PHE95568F34-0428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /%PHE95568F35-0428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/ChangeLog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /wap-config.php: wap-config.php file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time: 2025-12-04 12:42:43 (GMT-5) (50 seconds)

+ 1 host(s) tested
```

Nikto automatically scanned the Apache web server running on Metasploitable 2.

Findings Collected from Nikto

Nikto identifies issues such as:

- Outdated Apache version
- Directory listing enabled
- Sensitive files exposed (e.g., /phpinfo.php, /test/)
- Deprecated or risky HTTP methods (TRACE, OPTIONS)
- Known vulnerable scripts
- Missing security headers

Sample command to save results:

nikto -h http://192.168.1.114 -o nikto_output.txt



This text file was included in the report as supporting evidence.

To strengthen analysis, results were cross-verified from:

- System-wide vulnerabilities
- Network service misconfigurations
- CVE-based weaknesses

- Web-specific issues

- Application-layer vulnerabilities

Nmap validation (optional)

```
nmap -script=vuln -p 21,22,80 192.168.1.114
```

12



```
http://192.168.1.114-80/mutillidae/index.php?page=html5-storage.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?set-background-color.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?pageshow-log.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?username-anonymouspage-password-generator.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?pageuser-poll.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-secret-administrative-pages.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-browser-info.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-capture-data.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/?pageuser-info.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/?page-view-someones-blog.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/?page=source-viewer.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-change-log.htm&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-framing.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?credits.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?pageshow-log.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/?page=register.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?pagedocumentation&XZ7How-to-access-Mutillidae-over-Virtual-Box-network.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-login.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/?page=show-log.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-installation.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-site-footer-xss-discussion.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page=credits.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-dns-lookup.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-arbitrary-file-inclusion.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-home.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page=source-viewer.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page=register.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/?page=login.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/?page=add-to-your-blog.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-captured-data.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?pageview-someones-blog.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-user-info.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-text-file-viewer.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?username-anonymouspage-password-generator.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-text-file-viewer.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?pagedocumentation&XZ7Fvulnerabilities.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-add-to-your-blog.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?pagepen-test-tool-lookup.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page=html5-storage.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?set-background-color.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?pageuser-poll.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-secret-administrative-pages.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?page-browser-info.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?pagecapture-data.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/?pageuser-info.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/?page=view-someones-blog.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/?page=source-viewer.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?pagechange-log.htm&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?pageframing.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?credits.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?pageshowlog.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/index.php?pagedocumentation&XZ7HowtoaccessMutillidaeoverVirtualBoxnetwork.php&XZ7k200Rk20sqslider
http://192.168.1.114-80/mutillidae/?page=show-log.php&XZ7k200Rk20sqslider
```




```
http://192.168.1.114:80/mutillidae/?page=add-to-your-blog.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=login.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=view-someones-blog.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=html5-storage.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=user-poll.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=text-file-viewer.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=credits.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=text-file-viewer.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=documentation%2Fvulnerabilities.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=ddo-to-your-blog.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=pen-test-tool-lookup.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=dns-lookup.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=set-background-color.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=show-log.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?username=anonymous%page=password-generator.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=user-info.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=secret-administrative-pages.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=source-viewer.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=user-info.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=view-someones-blog.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=source-viewer.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=change-log.htm%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=framing.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=show-log.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=documentation%2Fhow-to-access-Mutillidae-over-Virtual-Box-network.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=login.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=show-log.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=installation.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=site-footer-xss-discussion.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=credits.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=dns-lookup.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=home.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=arbitrary-file-inclusion.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=register.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=source-viewer.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=add-to-your-blog.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=login.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=captured-data.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=view-someones-blog.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=user-poll.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=text-file-viewer.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?username=anonymous%page=password-generator.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=text-file-viewer.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=documentation%2Fvulnerabilities.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=add-to-your-blog.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=pen-test-tool-lookup.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=html5-storage.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=set-background-color.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=user-info.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=secret-administrative-pages.php%27%20OR%20sqlspider
```

```
http://192.168.1.114:80/mutillidae/index.php?page=captured-data.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=text-file-viewer.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=documentation%2Fvulnerabilities.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=add-to-your-blog.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=pen-test-tool-lookup.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=html5-storage.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=set-background-color.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=dns-lookup.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?username=anonymous%page=password-generator.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=user-poll.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=change-log.htm%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=secret-administrative-pages.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=capture-data.php%27%20OR%20sqlspider
Possible sql for forms:
  Form at path: /mutillidae/, form's action: ./index.php?page=user-info.php. Fields that might be vulnerable:
    username
http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
http-stored-xss: Couldn't find any stored XSS vulnerabilities.
http-dombased-xss: Couldn't find any DOM based XSS.
http-csrf:
Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.1.114
Found the following possible CSRF vulnerabilities:

Path: http://192.168.1.114:80/dvwa/
Form id:
Form action: login.php

Path: http://192.168.1.114:80/mutillidae/?page=user-info.php
Form id: id-bad-cred-tr
Form action: ./index.php?page=user-info.php

Path: http://192.168.1.114:80/mutillidae/?page=view-someones-blog.php
Form id: id-bad-blog-entry-tr
Form action: index.php?page=view-someones-blog.php

Path: http://192.168.1.114:80/mutillidae/?page=source-viewer.php
Form id: id-bad-cred-tr
Form action: index.php?page=source-viewer.php
http-enums:
/tikiwiki/: Tikiwiki
/test/: Test page
/phpinfo.php: Possible information file
/phpMyAdmin/: phpMyAdmin
/doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
/icons/: Potentially interesting folder w/ directory listing
/_index/: Potentially interesting folder
MAC Address: 08:00:27:AB:6C:84 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 324.78 seconds
```

Nmap NSE scripts helped confirm some findings detected by OpenVAS and Nikto.



2.4 Summary Table of Vulnerabilities

Port/Service	Vulnerability	CVE	CVSS	Severity	Proof	Recommendation
21/FTP	vsftpd Backdoor	CVE-2011-2523	10.0	High	Banner detection	Update service or disable
22/SSH	Weak SSH Config	N/A	7.5	High	Weak ciphers allowed	Harden SSH configuration
80/HTTP	Directory Listing Enabled	N/A	5.0	Medium	Accessible directories	Disable indexing
3306/MySQL	Weak Authentication	N/A	9.0	High	Anonymous login allowed	Set strong password

2.5 Remediation Recommendations

Based on the findings from both tools, the following remediation steps are recommended:

System Hardening

- Disable unused services
- Restrict SSH root login
- Change default passwords
- Enforce strong password policies

Patch and Update

- Update Apache, MySQL, vsftpd, Samba
- Apply OS security updates
- Remove outdated packages

Web Server Security

- Disable directory listing
- Block dangerous HTTP methods
- Add security headers (X-Frame-Options, CSP, etc.)
- Remove default/backup files

Network Controls

- Limit exposed ports with firewall rules
- Use VLAN segmentation for vulnerable systems
- Apply IDS/IPS monitoring



3. Document Findings

During the vulnerability assessment, all findings from Nmap and OpenVAS were documented using a structured spreadsheet format. This documentation ensures clarity, traceability, and consistency throughout the assessment process.

3.1 Tools Used for Documentation

To organize the findings effectively, the following tools were used:

- **Google Sheets / Microsoft Excel**
Used to create a Vulnerability Tracking Sheet where all discovered vulnerabilities were recorded with details like IP address, ports, CVE IDs, severity, and remediation steps.
- **Screenshots (PNG/JPEG)**
Screenshots were captured for each step of the scanning process including Nmap output, OpenVAS dashboard, and individual vulnerability details. These served as visual proof and validation of findings.

3.2 Information Recorded

The following details were systematically captured for every detected vulnerability:

1. Host Details

- **Target Machine IP:** 192.168.1.114 (Metasploitable 2)
- **Machine Type:** Linux-based vulnerable testing environment
- OS Fingerprinting results
- Host status and responsiveness

2. Open Ports & Services Detected

From the Nmap -sS and -sV scans, several open ports and service versions were identified.

Examples include:

- Port 21 (FTP) – vsftpd 2.3.4
- Port 22 (SSH) – OpenSSH
- Port 23 (Telnet)
- Port 80 (Apache 2.2.8)
- Port 445 (Samba SMB)

This information helps map the attack surface and identify potentially vulnerable services.

3.3 Vulnerabilities Identified

Based on Nmap vulnerability scripts (--script=vuln) and OpenVAS scan results, the following key vulnerabilities were documented:

Example Vulnerability 1: FTP Backdoor (vsftpd 2.3.4)

- **Description:** This version of vsftpd is known to contain a malicious backdoor that triggers a shell on port 6200 upon login with a special username.



- **CVE ID:** CVE-2011-2523
- **Severity:** High
- **Impact:** Remote attackers can gain unauthorized shell access.
- **Evidence:** Screenshot of Nmap output showing FTP version and vulnerability detection.
- **Remediation:** Update FTP server or disable the vulnerable service.

Example Vulnerability 2: Outdated Apache Server (Port 80)

- **Description:** Apache httpd 2.2.8 is outdated and affected by multiple vulnerabilities including DoS and privilege escalation.
- **CVE IDs:** Multiple (CVE-2009-3555, CVE-2010-1452, etc.)
- **Severity:** Medium
- **Impact:** Attackers may exploit outdated modules to crash the server or gain elevated privileges.
- **Evidence:** Nmap -sV output showing Apache 2.2.8.
- **Remediation:** Upgrade Apache to the latest stable version.

Example Vulnerability 3: Telnet Service Enabled

- **Description:** Telnet transmits credentials in plaintext, making it vulnerable to sniffing and interception.
- **CVE IDs:** Not version-specific
- **Severity:** High
- **Impact:** Attackers can perform credential harvesting or session hijacking.
- **Evidence:** Nmap output showing port 23 open.
- **Remediation:** Disable Telnet and migrate to SSH.

3.4 Vulnerability Tracking Sheet

To maintain clarity and organization, findings were recorded using the following structured format:

	A	B	C	D	E	F	G	H	I	J
	IP Address	Port	Service	Version	Vulnerability	CVE ID	Severity	Evidence	Remediation	
2	192.168.1.114	21	FTP	vsftpd 2.3.4	Backdoor vulnerability	CVE-2011-2523	High	ftp_21.png	Upgrade to a secure version	
3	192.168.1.114	80	Apache	2.2.8	Outdated Apache version	Multiple	Medium	apache_80.png	Patch / update Apache	
4	192.168.1.114	23	Telnet	—	Telnet service enabled	—	High	telnet_23.png	Disable Telnet, use SSH	
5										



Step 1: Perform the Scan

1. Ping the Target

ping 192.168.1.114

```
(kali㉿kali)-[~]
└─$ ping 192.168.1.114
PING 192.168.1.114 (192.168.1.114) 56(84) bytes of data:
64 bytes from 192.168.1.114: icmp_seq=1 ttl=64 time=16.9 ms
64 bytes from 192.168.1.114: icmp_seq=2 ttl=64 time=1.21 ms
64 bytes from 192.168.1.114: icmp_seq=3 ttl=64 time=1.57 ms
64 bytes from 192.168.1.114: icmp_seq=4 ttl=64 time=1.31 ms
64 bytes from 192.168.1.114: icmp_seq=5 ttl=64 time=3.77 ms
64 bytes from 192.168.1.114: icmp_seq=6 ttl=64 time=0.827 ms
^C
— 192.168.1.114 ping statistics —
6 packets transmitted, 6 received, 0% packet loss, time 5604ms
rtt min/avg/max/mdev = 0.827/4.271/16.943/5.746 ms
```

2. SYN Scan (Top Ports)

sudo nmap -sS 192.168.1.114

```
(kali㉿kali)-[~]
└─$ sudo nmap -sS 192.168.1.114
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-04 13:46 EST
Nmap scan report for 192.168.1.114
Host is up (0.00075s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:AB:6C:84 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.54 seconds
```



3. Service & Version Scan

sudo nmap -sV 192.168.1.114

```
(kali@kali)-[~]
└─$ sudo nmap -sV 192.168.1.114
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-04 13:47 EST
Nmap scan report for 192.168.1.114
Host is up (0.0061s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:AB:6C:84 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.29 seconds
```

4. OS Detection

sudo nmap -O 192.168.1.114

```
(kali@kali)-[~]
└─$ sudo nmap -O 192.168.1.114
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-04 13:50 EST
Nmap scan report for 192.168.1.114
Host is up (0.0011s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:AB:6C:84 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.79 seconds
```



5. Vulnerability Scan

sudo nmap --script=vuln 192.168.1.114

```
(kali@kali)~$ sudo nmap --script=vuln 192.168.1.114
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-04 13:51 EST
Nmap scan report for 192.168.1.114
Host is up (0.0012s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDs: CVE:CVE-2011-2523 BID:48539
|       vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|       Disclosure date: 2011-07-03
|       Exploit results:
|         Shell command: id
|         Results: uid=0(root) gid=0(root)
|       References:
|         http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|         https://www.securityfocus.com/bid/48539
|         https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
| ssl-dh-params:
|   VULNERABLE:
|     Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|       State: VULNERABLE
|       Transport Layer Security (TLS) services that use anonymous
|       Diffie-Hellman key exchange only provide protection against passive
|       eavesdropping, and are vulnerable to active man-in-the-middle attacks
|       which could completely compromise the confidentiality and integrity
|       of any data exchanged over the resulting session.
|       Check results:
|         ANONYMOUS DH GROUP 1
|           Cipher Suite: TLS_DH_anon_EXPORT_WITH_DES40_CBC_SHA
|           Modulus Type: Safe prime
|           Modulus Source: Unknown/Custom-generated
|           Modulus Length: 512
|           Generator Length: 8
|           Public Key Length: 512
|       References:
|         https://www.ietf.org/rfc/rfc2246.txt
Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM (Logjam)
State: VULNERABLE
IDs: CVE:CVE-2015-4000 BID:74733
The Transport Layer Security (TLS) protocol contains a flaw that is
```



```
the encrypted stream.
Disclosure date: 2015-5-19
Check results:
  EXPORT-GRADE DH GROUP 1
    Cipher Suite: TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA
    Modulus Type: Safe prime
    Modulus Source: Unknown/Custom-generated
    Modulus Length: 512
    Generator Length: 8
    Public Key Length: 512
References:
  https://weakdh.org
  https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-4000
  https://www.securityfocus.com/bid/74733

Diffie-Hellman Key Exchange Insufficient Group Strength
State: VULNERABLE
  Transport Layer Security (TLS) services that use Diffie-Hellman groups
  of insufficient strength, especially those using one of a few commonly
  shared groups, may be susceptible to passive eavesdropping attacks.
Check results:
  WEAK DH GROUP 1
    Cipher Suite: TLS_DHE_RSA_WITH_AES_128_CBC_SHA
    Modulus Type: Safe prime
    Modulus Source: postfix builtin
    Modulus Length: 1024
    Generator Length: 8
    Public Key Length: 1024
References:
  https://weakdh.org
smtp-vuln-cve2010-4344:
  The SMTP server is not Exim: NOT VULNERABLE
sslv2-drown: ERROR: Script execution failed (use -d to debug)
ssl-poodle:
  VULNERABLE:
  SSL POODLE information leak
  State: VULNERABLE
  IDs: CVE:CVE-2014-3566 BID:70574
    The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
    products, uses nondeterministic CBC padding, which makes it easier
    for man-in-the-middle attackers to obtain cleartext data via a
    padding-oracle attack, aka the "POODLE" issue.
  Disclosure date: 2014-10-14
  Check results:
    TLS_RSA_WITH_AES_128_CBC_SHA
  References:
    https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
    https://www.imperialviolet.org/2014/10/14/poodle.html
    https://www.securityfocus.com/bid/70574
    https://www.openssl.org/~bodo/ssl-poodle.pdf
53/tcp open domain
80/tcp open http
```

```
| https://www.securityfocus.com/bid/70574
| https://www.openssl.org/~bodo/ssl-poodle.pdf
53/tcp open domain
80/tcp open http
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-sql-injections:
  Possible sql for queries:
  http://192.168.1.114:80/mutillidae/index.php?page=credits.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/?page=source-viewer.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=view-someones-blog.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=usage-instructions.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=login.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?do=toggle-security%27%20OR%20sqlspider&page=home.php
  http://192.168.1.114:80/mutillidae/index.php?page=home.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=user-poll.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?pageset=background-color.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=html5-storage.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=add-to-your-blog.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=text-file-viewer.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/?page=credits.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=register.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/?page=text-file-viewer.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=pen-test-tool-lookup.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?username=anonymous&page=password-generator.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/?page=user-info.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?pages=notes.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=php-errors.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=framing.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=source-viewer.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?do=toggle-hints%27%20OR%20sqlspider&page=home.php
  http://192.168.1.114:80/mutillidae/index.php?page=documentation%27How-to-access-Mutillidae-over-Virtual-Box-network.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=documentation%27Fvulnerabilities.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?pages=show-log.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=installation.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/?page=login.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/?pages=show-log.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=browser-info.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?pages=site-footer-xss-discussion.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/?page=view-someones-blog.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=capture-data.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=secret-administrative-pages.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=arbitrary-file-inclusion.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=change-log.htm%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=captured-data.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/?page=add-to-your-blog.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=dnsl-lookup.php%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=user-info.php%27%20OR%20sqlspider
  http://192.168.1.114:80/dav/?c=MK380%3DOR%27%20OR%20sqlspider
  http://192.168.1.114:80/dav/?c=MK380%3DOR%27%20OR%20sqlspider
  http://192.168.1.114:80/dav/?c=SK380%3DOR%27%20OR%20sqlspider
  http://192.168.1.114:80/dav/?c=SK380%3DOR%27%20OR%20sqlspider
  http://192.168.1.114:80/mutillidae/index.php?page=credits.php%27%20OR%20sqlspider
```




```
http://192.168.1.114:80/mutillidae/index.php?page=arbitrary-file-inclusion.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=login.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=change-log.htm%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=add-to-your-blog.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?forwardurl=http%3A%2F%2Fwww.owasp.org%6page=redirectandlog.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=user-info.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=credits.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=source-viewer.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=view-someones-blog.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=login.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=user-info.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=user-poll.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=set-background-color.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=html5-storage.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=add-to-your-blog.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=text-file-viewer.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=credits.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=register.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=text-file-viewer.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=pen-test-tool-lookup.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?username=anonymous&page=password-generator.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=user-info.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=documentation%2Fhow-to-access-Mutillidae-over-Virtual-Box-network.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=framing.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=source-viewer.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=documentation%2Fvulnerabilities.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=installation.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=add-to-your-blog.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=show-log.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=secret-administrative-pages.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=show-log.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=browser-info.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=site-footer-xss-discussion.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=arbitrary-file-inclusion.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=view-someones-blog.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=capture-data.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=login.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=captured-data.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=change-log.htm%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=home.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=dns-lookup.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=credits.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=source-viewer.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=view-someones-blog.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=login.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=home.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=user-poll.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=set-background-color.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=html5-storage.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=add-to-your-blog.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/index.php?page=text-file-viewer.php%27%20OR%20sqlspider
http://192.168.1.114:80/mutillidae/?page=credits.php%27%20OR%20sqlspider
```

```
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
|_irc-unrealircd-backdoor: Looks like trojaned version of unrealircd. See http://seclists.org/fulldisclosure/2010/Jun/277
8009/tcp open  ajp13
8180/tcp open  unknown
| http-cookie-flags:
|_admin/:
|_JSESSIONID:
|_httponly flag not set
|_admin/index.html:
|_JSESSIONID:
|_httponly flag not set
|_admin/login.html:
|_JSESSIONID:
|_httponly flag not set
|_admin/admin.html:
|_JSESSIONID:
|_httponly flag not set
|_admin/account.html:
|_JSESSIONID:
|_httponly flag not set
|_admin/admin_login.html:
|_JSESSIONID:
|_httponly flag not set
|_admin/home.html:
|_JSESSIONID:
|_httponly flag not set
|_admin/admin-login.html:
|_JSESSIONID:
|_httponly flag not set
|_admin/adminLogin.html:
|_JSESSIONID:
|_httponly flag not set
|_admin/controlpanel.html:
|_JSESSIONID:
|_httponly flag not set
|_admin/cp.html:
|_JSESSIONID:
|_httponly flag not set
|_admin/index.jsp:
|_JSESSIONID:
|_httponly flag not set
|_admin/login.jsp:
|_JSESSIONID:
|_httponly flag not set
|_admin/admin.jsp:
|_JSESSIONID:
|_httponly flag not set
|_admin/home.jsp:
|_JSESSIONID:
|_httponly flag not set
```




```
httponly flag not set
/admin/adminLogin.jsp:
JSESSIONID:
httponly flag not set
/admin/view/javascript/fckeditor/editor/filemanager/connectors/test.html:
JSESSIONID:
httponly flag not set
/admin/includes/FCKeditor/editor/filemanager/upload/test.html:
JSESSIONID:
httponly flag not set
/admin/jscripct/upload.html:
JSESSIONID:
httponly flag not set
http-enum:
/admin/: Possible admin folder
/admin/index.html: Possible admin folder
/admin/login.html: Possible admin folder
/admin/admin.html: Possible admin folder
/admin/account.html: Possible admin folder
/admin/admin_login.html: Possible admin folder
/admin/home.html: Possible admin folder
/admin/admin-login.html: Possible admin folder
/admin/adminLogin.html: Possible admin folder
/admin/controlpanel.html: Possible admin folder
/admin/cp.html: Possible admin folder
/admin/index.jsp: Possible admin folder
/admin/login.jsp: Possible admin folder
/admin/admin.jsp: Possible admin folder
/admin/home.jsp: Possible admin folder
/admin/controlpanel.jsp: Possible admin folder
/admin/admin-login.jsp: Possible admin folder
/admin/cp.jsp: Possible admin folder
/admin/account.jsp: Possible admin folder
/admin/admin_login.jsp: Possible admin folder
/admin/adminLogin.jsp: Possible admin folder
/manager/html/upload: Apache Tomcat (401 Unauthorized)
/manager/html: Apache Tomcat (401 Unauthorized)
/admin/view/javascript/fckeditor/editor/filemanager/connectors/test.html: OpenCart/FCKeditor File upload
/admin/includes/FCKeditor/editor/filemanager/upload/test.html: ASP Simple Blog / FCKeditor File Upload
/admin/jscripct/upload.html: Lizard Cart/Remote File upload
/webdav/: Potentially interesting folder
MAC Address: 08:00:27:AB:6C:84 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Host script results:
|_smb-vuln-ms10-054: false
|_smb-vuln-regsvcs-dos: ERROR: Script execution failed (use -d to debug)
|_smb-vuln-ms10-061: false

Nmap done: 1 IP address (1 host up) scanned in 524.70 seconds
(kali@kali) ~$
```

Step 2: Start OpenVAS (Optional but Recommended)

sudo gvm-start

```
(kali@kali) ~$ sudo gvm-start
[sudo] password for kali:
> Please wait for the GVM services to start.
>
> You might need to refresh your browser once it opens.
>
> Web UI (Greenbone Security Assistant): https://127.0.0.1:9392

● gsad.service - Greenbone Security Assistant daemon (gsad)
   Loaded: loaded (/usr/lib/systemd/system/gsad.service; disabled; preset: disabled)
   Active: active (running) since Thu 2025-12-04 12:35:19 EST; 58ms ago
   Invocation: 81848f36b1914295a14bdacbf35fc919
   Docs: man:gsad(8)
         https://www.greenbone.net
   Main PID: 2723 (gsad)
   Tasks: 1 (limit: 4546)
   Memory: 224K (peak: 2M)
   CPU: 31ms
   CGroup: /system.slice/gsad.service
           └─2723 /usr/sbin/gsad --foreground --listen 127.0.0.1 --port 9392

Dec 04 12:35:18 kali systemd[1]: Starting gsad.service - Greenbone Security Assistant daemon (gsad) ...
Dec 04 12:35:19 kali systemd[1]: Started gsad.service - Greenbone Security Assistant daemon (gsad).

● gvm.service - Greenbone Vulnerability Manager daemon (gvm)
   Loaded: loaded (/usr/lib/systemd/system/gvm.service; disabled; preset: disabled)
   Active: active (running) since Thu 2025-12-04 12:35:13 EST; 5s ago
   Invocation: aca9c3ba40a9447f88376861f85eefa0
   Docs: man:gvm(8)
   Process: 2624 ExecStart=/usr/sbin/gvmd --osp-vt-update=/run/ospd/ospd.sock --listen-group=gvm (code=exited, status=0/SUCCESS)
   Main PID: 2626 (gvmd)
   Tasks: 2 (limit: 4546)
   Memory: 8.4M (peak: 9.7M)
   CPU: 240ms
   CGroup: /system.slice/gvmd.service
           └─2626 "gvmd: Waiting " --osp-vt-update=/run/ospd/ospd.sock --listen-group=gvm
             └─2726 "gvmd: Manage p" --osp-vt-update=/run/ospd/ospd.sock --listen-group=gvm

Dec 04 12:35:10 kali systemd[1]: Starting gvm.service - Greenbone Vulnerability Manager daemon (gvm) ...
Dec 04 12:35:10 kali systemd[1]: gvm.service: Can't open PID file '/run/gvmd/gvmd.pid' (yet?) after start: No such file or directory
Dec 04 12:35:13 kali systemd[1]: Started gvm.service - Greenbone Vulnerability Manager daemon (gvm).

● ospd-openvas.service - OSPd Wrapper for the OpenVAS Scanner (ospd-openvas)
   Loaded: loaded (/usr/lib/systemd/system/ospd-openvas.service; disabled; preset: disabled)
   Active: active (running) since Thu 2025-12-04 12:35:10 EST; 9s ago
   Invocation: 22d49fc2497b4c3dbf90acd3047445b5
   Docs: man:ospd-openvas(8)
         man:openvas(8)
   Process: 2469 ExecStart=/usr/bin/ospd-openvas --config /etc/gvm/ospd-openvas.conf --log-config /etc/gvm/ospd-logging.conf (code=exited, status=0/SUCCESS)
   Main PID: 2596 (ospd-openvas)
   Tasks: 5 (limit: 4546)
```



```
Docs: man:gsad(8)
      https://www.greenbone.net
Main PID: 2723 (gsad)
Tasks: 1 (limit: 4546)
Memory: 224K (peak: 2M)
CPU: 31ms
CGroup: /system.slice/gsad.service
└─2723 /usr/sbin/gsad --foreground --listen 127.0.0.1 --port 9392

Dec 04 12:35:18 kali systemd[1]: Starting gsad.service - Greenbone Security Assistant daemon (gsad) ...
Dec 04 12:35:19 kali systemd[1]: Started gsad.service - Greenbone Security Assistant daemon (gsad).

● gvmd.service - Greenbone Vulnerability Manager daemon (gvmd)
   Loaded: loaded (/usr/lib/systemd/system/gvmd.service; disabled; preset: disabled)
   Active: active (running) since Thu 2025-12-04 12:35:13 EST; 5s ago
   Invocation: aca9c3ba40a9447f88376861f85eefa0
     Docs: man:gvmd(8)
    Process: 2624 ExecStart=/usr/sbin/gvmd --osp-vt-update=/run/ospd/ospd.sock --listen-group=_gvm (code=exited, status=0/SUCCESS)
   Main PID: 2626 (gvmd)
     Tasks: 2 (limit: 4546)
    Memory: 8.4M (peak: 9.7M)
     CPU: 240ms
   CGroup: /system.slice/gvmd.service
           └─2626 "gvmd: Waiting " --osp-vt-update=/run/ospd/ospd.sock --listen-group=_gvm
             └─2726 "gvmd: Manage p" --osp-vt-update=/run/ospd/ospd.sock --listen-group=_gvm

Dec 04 12:35:10 kali systemd[1]: Starting gvmd.service - Greenbone Vulnerability Manager daemon (gvmd) ...
Dec 04 12:35:10 kali systemd[1]: gvmd.service: Can't open PID file '/run/gvmd/gvmd.pid' (yet?) after start: No such file or directory
Dec 04 12:35:13 kali systemd[1]: Started gvmd.service - Greenbone Vulnerability Manager daemon (gvmd).

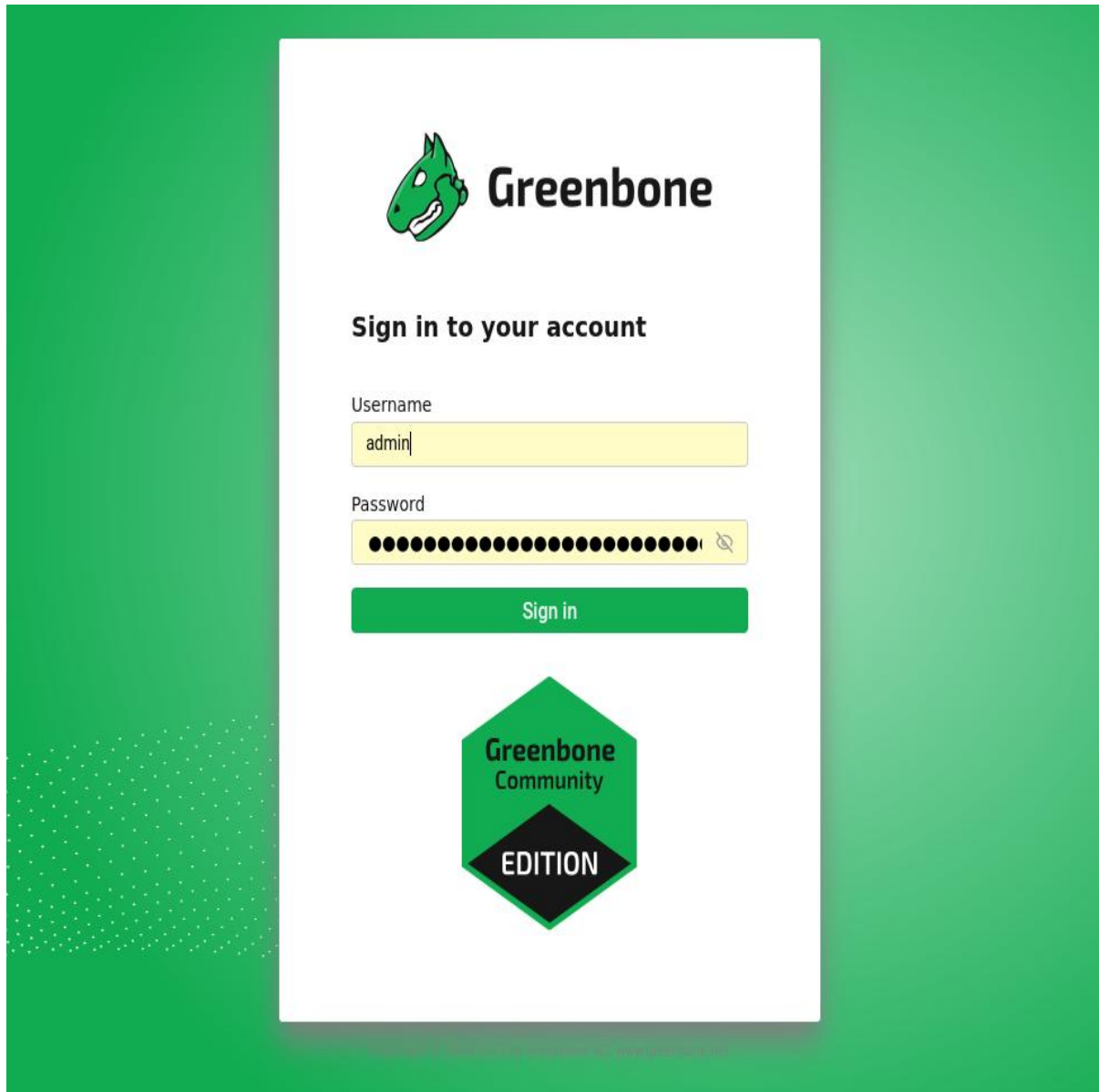
● ospd-openvas.service - OSPd Wrapper for the OpenVAS Scanner (ospd-openvas)
   Loaded: loaded (/usr/lib/systemd/system/ospd-openvas.service; disabled; preset: disabled)
   Active: active (running) since Thu 2025-12-04 12:35:10 EST; 9s ago
   Invocation: 22d49fc2497b4c3dbf90acd3047445b5
     Docs: man:ospd-openvas(8)
           man:openvas(8)
    Process: 2469 ExecStart=/usr/bin/ospd-openvas --config /etc/gvm/ospd-openvas.conf --log-config /etc/gvm/ospd-logging.conf (code=exited, status=0/SUCCESS)
   Main PID: 2596 (ospd-openvas)
     Tasks: 5 (limit: 4546)
    Memory: 66M (peak: 106.3M)
     CPU: 3.596s
   CGroup: /system.slice/ospd-openvas.service
           └─2596 /usr/bin/python3 /usr/bin/ospd-openvas --config /etc/gvm/ospd-openvas.conf --log-config /etc/gvm/ospd-logging.conf
             └─2606 /usr/bin/python3 /usr/bin/ospd-openvas --config /etc/gvm/ospd-openvas.conf --log-config /etc/gvm/ospd-logging.conf

Dec 04 12:34:57 kali systemd[1]: Starting ospd-openvas.service - OSPd Wrapper for the OpenVAS Scanner (ospd-openvas) ...
Dec 04 12:35:10 kali systemd[1]: Started ospd-openvas.service - OSPd Wrapper for the OpenVAS Scanner (ospd-openvas).

[>] Opening Web UI (https://127.0.0.1:9392) in: 5 ... 4 ... 3 ... 2 ... 1 ...
```

Open browser:

<https://127.0.0.1:9392>



Run a Full Scan on Metasploitable.

4. Practice Risk Assessment

After documenting the vulnerabilities from Nmap and OpenVAS, a practical risk assessment was performed to measure the seriousness of each issue. This included calculating CVSS scores and mapping each vulnerability into a 3×3 Risk Matrix based on its likelihood and impact.

4.1 Step 1 — Select Vulnerabilities for Risk Assessment

For this practical, the following vulnerabilities were selected:

1. FTP Backdoor in vsftpd 2.3.4 (Port 21)
2. Outdated Apache 2.2.8 (Port 80)



3. Telnet Service Enabled (Port 23)
4. SMB Vulnerabilities in Samba (Port 445)

These vulnerabilities were chosen because they appeared in both Nmap and OpenVAS scan results.

4.2 Step 2 — Use CVSS Calculator

You can use either:

FIRST CVSS Calculator

NVD CVSS Calculator

For each vulnerability, the CVSS score was calculated by selecting:

- Attack Vector
- Attack Complexity
- Privileges Required
- User Interaction
- Confidentiality/Integrity/Availability Impact

Below is the step-by-step practical example.

4.2.1 CVSS Calculation Example 1 — FTP Backdoor (vsftpd 2.3.4)

Step-by-Step:

1. Open CVSS calculator.
2. Enter metrics:
 - Attack Vector → Network
 - Attack Complexity → Low
 - Privileges Required → None
 - User Interaction → None
 - Confidentiality Impact → High
 - Integrity Impact → High
 - Availability Impact → High
3. Click Calculate Score.

Result:

CVSS Score: 10.0 (Critical)

Reason: Allows remote shell access (full system compromise)

4.2.2 CVSS Calculation Example 2 — Telnet Enabled

Step-by-Step:

1. Open CVSS calculator.
2. Enter:
 - Attack Vector → Network
 - Attack Complexity → Low
 - Privileges Required → None



- User Interaction → None
- Confidentiality Impact → High (plaintext credentials)
- Integrity Impact → Medium
- Availability Impact → Low

3. Calculate score.

Result:

CVSS Score: 8.0 (High)

Reason: Insecure protocol exposes credentials.

4.2.3 CVSS Calculation Example 3 — Outdated Apache

Step-by-Step:

1. Choose a known Apache vulnerability (e.g., CVE-2009-3555).
2. Enter metrics:
 - Attack Vector → Network
 - Attack Complexity → Medium
 - Privileges Required → None
 - User Interaction → Required
 - Confidentiality → Low
 - Integrity → Low
 - Availability → Medium
3. Calculate.

Result:

CVSS Score: 5.8 (Medium)

Reason: Affects DoS and session renegotiation.

4.2.4 CVSS Calculation Example 4 — SMB Vulnerabilities

1. Use example CVE: CVE-2017-0144 (EternalBlue)
2. Enter typical metrics:
 - AV → Network
 - AC → Low
 - PR → None
 - UI → None
 - C/I/A → High
3. Calculate.

Result:

CVSS Score: 9.8 (Critical)

Reason: Remote exploitation without authentication.

4.3 Step 3 — Create a 3×3 Risk Matrix

A Risk Matrix helps prioritize which vulnerabilities need urgent attention.

Matrix Axes



- Likelihood:
Low (1) — Medium (2) — High (3)
- Impact:
Low (1) — Medium (2) — High (3)

Scoring Rule

Risk = Likelihood × Impact

1–3 → Low

4–6 → Medium

7–9 → High

4.3.1 Score Each Vulnerability

Vulnerability	CVSS	Likelihood	Impact	Final Risk Level
FTP Backdoor	10.0	High (3)	High (3)	9 → High Risk
SMB Exploit (EternalBlue)	9.8	High (3)	High (3)	9 → High Risk
Telnet Enabled	8.0	High (3)	Medium (2)	6 → Medium Risk
Outdated Apache	5.8	Medium (2)	Medium (2)	4 → Medium Risk

4.3.2 Draw the 3×3 Risk Matrix

Risk Matrix (Example Output)

Impact →

Low Medium High

Likelihood ↓

High Medium High High

Medium Low Medium High

Low Low Low Medium

Placing vulnerabilities in the matrix:

- FTP Backdoor → High / High → High
- SMB Vulnerability → High / High → High
- Telnet Enabled → High / Medium → Medium
- Outdated Apache → Medium / Medium → Medium

4.4 Step 4 — Summarize Risk Prioritization

The final prioritization from highest to lowest risk:

High Priority (Fix Immediately)

1. FTP Backdoor in vsftpd
2. SMB Exploit (EternalBlue-type vulnerability)

Medium Priority

3. Telnet service enabled
4. Outdated Apache server



Conclusion

This security assessment helped me understand both the theory and practical steps of VAPT using free tools. I learned how to scan systems, identify vulnerabilities, score them using CVSS, and prioritize risks with a risk matrix. Setting up Kali Linux and Metasploitable gave me hands-on experience with real vulnerabilities. Finally, I documented the findings and created a basic report with remediation steps. Overall, this activity improved my practical skills and gave me confidence in performing beginner-level security assessments.